AI Hardware Security Compliance Portfolio

Industry-ready portfolio aligned to compliance, certification, and audit workflows

Prepared for: Brojogopal Sapui
Date: 6 April 2026

Portfolio purpose	Translate PhD research into the language used by compliance engineers, certification teams, auditors, and hiring managers.
Primary frameworks	ISO/SAE 21434 style cybersecurity work products; Common Criteria style evaluation packages; audit-oriented evidence and traceability.
Technical domains covered	Side-channel analysis, fault injection, secure accelerator design, hardware verification, masking, device-level security.
Important note	This portfolio is a professionally structured alignment document. It is not an official certification submission and does not claim formal assessor approval.

Confidential working portfolio - prepared for professional positioning and interview use.

Contents

1. Executive overview
2. How to read this portfolio
3. Professional profile and positioning
4. Compliance lens used in this document
5. Portfolio architecture and evidence model
6. Project dossier A - HDC side-channel security
7. Project dossier B - fault injection and robustness
8. Project dossier C - secure HDC accelerator design and verification
9. Project dossier D - device-level and emerging hardware security
10. Cross-project traceability matrix
11. Certification-style work products
12. Audit and evidence package
13. Role mapping for industry jobs
14. Interview stories and CV bullets
15. Personal gap-closure plan
16. Final positioning statement

Appendix A - standards language quick reference

Appendix B - evidence inventory template

1. Executive overview

This portfolio converts a deep technical PhD body of work into a set of compliance-oriented deliverables that resemble how employees document cybersecurity engineering inside semiconductor, automotive, embedded-AI, and certification-facing organizations.

The central idea is simple: the same research that demonstrates attacks, defenses, architectures, and validation results can be reframed as threat analysis, vulnerability analysis, control design, verification evidence, residual risk, and audit traceability.

The portfolio focuses on four core research streams: side-channel attacks on Hyperdimensional Computing (HDC) accelerators, fault injection campaigns and countermeasures, secure AI accelerator design and verification, and device-level security work on emerging hardware technologies.

It is intentionally written in a style that can be understood by three audiences at once: hiring managers, compliance engineers, and technically deep reviewers.

- Use this document as a professional attachment for job applications, interviews, networking follow-up, or performance review discussions.
- Use the project dossiers as templates for converting any future paper or prototype into compliance-language work products.
- Use the appendices as a quick reference for how engineers talk about evidence, traceability, assurance, and residual risk.

2. How to read this portfolio

Each project dossier follows the same structure. First, the technical system is described. Second, the sensitive assets are identified. Third, the credible attacker actions are described. Fourth, the vulnerabilities and attack surfaces are stated in language suitable for risk and audit workflows. Fifth, the implemented or proposed controls are documented. Sixth, the validation evidence is summarized. Finally, the residual risk and next-step recommendations are recorded.

A compliance portfolio is not a replacement for technical depth. It is the packaging layer that proves the technical work can be governed, reviewed, and defended inside a real company process.

- When a sentence says 'aligned to' a framework, it means the work can be mapped into the structure of that framework.
- When a sentence says 'evidence', it means the output that a reviewer can inspect: logs, reports, traces, test results, scripts, verification artifacts, or measured data.
- When a sentence says 'residual risk', it means the risk that remains after a control is applied.

3. Professional profile and positioning

Primary identity: hardware and AI security researcher with deep hands-on experience in side-channel analysis, fault injection, secure accelerator design, and hardware-aware countermeasure development.

Professional differentiation: unlike many compliance candidates who mainly understand documentation, this profile combines attack realism, implementation detail, and measurement-backed validation. That is valuable because most certification and audit programs fail when the underlying technical reasoning is weak.

Industry translation: this profile fits roles such as AI Hardware Security Engineer, Security Certification Engineer, Product Security Architect, Security Evaluation Engineer, Hardware Threat Modeling Engineer, Security Compliance Engineer, and ML Platform Security Engineer.

- Strength 1 - ability to model practical attackers rather than paper-only threats.
- Strength 2 - ability to implement countermeasures and measure their effect.
- Strength 3 - ability to connect hardware design decisions to evidence that auditors can review.
- Strength 4 - ability to operate across device, circuit, architecture, FPGA, and system-validation layers.

4. Compliance lens used in this document

This document uses an engineering-oriented compliance lens instead of a legal or policy-only lens. The emphasis is on security work products that employees actually create: threat analysis, risk narratives, architecture notes, control descriptions, verification plans, leakage assessments, evidence tables, and traceability matrices.

Two framework families are emphasized because they are highly relevant to the user's target roles. The first is ISO/SAE 21434 style cybersecurity engineering, useful for structured threat analysis and validation in automotive or edge products. The second is Common Criteria style evaluation thinking, useful for security targets, assurance reasoning, evaluator communication, and structured claims about a target of evaluation.

The document also adopts an audit mindset. Auditors typically ask three questions: what is the claim, what is the evidence, and how do you know the evidence actually supports the claim. Every major section below is designed to answer those questions.

5. Portfolio architecture and evidence model

The portfolio is organized around the progression research -> threat -> vulnerability -> control -> evidence -> residual risk -> role relevance.

That progression mirrors how employees in mature security organizations communicate across engineering, product, compliance, and assurance teams. A technically strong employee is especially valuable when they can translate raw research outputs into this operational chain without losing fidelity.

- Research output: paper, experiment, prototype, RTL block, simulation result, or device model.
- Threat statement: what an attacker is trying to achieve and under what assumptions.
- Vulnerability statement: what in the design enables the attack or increases feasibility.
- Control statement: what was implemented or proposed to reduce the risk.
- Evidence statement: what measured result or artifact supports that the control works.
- Residual risk statement: what remains unresolved and what future improvement is required.

Portfolio summary table

Project stream	Primary asset	Main threat	Representative control	Key evidence
HDC side-channel security	Stored class hypervectors / model IP	Passive power-based model extraction	Dynamic masking	Attack accuracy reduction and TVLA
Fault injection campaigns	Inference correctness / decision integrity	Voltage glitching and timing disturbance	Timing-aware protection and validation	Misclassification campaigns and mitigation observations
Secure accelerator design	Runtime data path and memory movement	Leakage and exploitable micro-architectural behavior	Secure design choices + verification	RTL evidence, simulation, profiling
Device-level security	Low-level device behavior and entropy/security primitives	Leakage, predictability, exploitable physical behavior	Bias masking / secure circuit concepts	Modeling and architecture argumentation

6. Project dossier A - HDC side-channel security

This dossier is based on the FPGA-oriented HDC side-channel work in which deep-learning-assisted analysis was used to extract information from an HDC accelerator implementation. The technical storyline is highly valuable for compliance roles because it already contains all core elements of a mature security case: asset identification, realistic attacker access, measured evidence, targeted countermeasure design, and post-control evaluation.

The system context is an FPGA-based HDC accelerator performing encoding and similarity computation with stored class hypervectors. The protected asset is not merely data in memory; it is trained model intellectual property. That framing matters because companies care deeply about IP theft, competitive differentiation, and model reconstruction risk.

6.1 Asset definition and business relevance

The principal asset is the class hypervector set stored in associative memory. Those hypervectors encode the trained model and therefore capture proprietary inference capability. In a company setting, that means unauthorized recovery could enable model cloning, reverse engineering, performance replication, and loss of product differentiation.

A secondary asset is the integrity of the inference pipeline itself, because leakage often exposes internal computation phases that can later be exploited for higher-confidence attacks or tuning of attack windows.

6.2 Threat scenario

A realistic adversary obtains physical or near-physical measurement access to the FPGA device and records power traces during inference. The adversary does not require source code modification or logical compromise. Instead, the attack is passive and relies on observing leakage from normal device operation.

The attacker goal is model extraction. More specifically, the attacker aims to infer bits of stored hypervectors by learning patterns in side-channel traces. The work shows that a machine-learning-based attacker can do this effectively when trace quality and training are sufficient.

6.3 Vulnerability analysis

The vulnerability is rooted in observable side-channel leakage associated with HDC operations such as XOR and popcount-like behavior during similarity calculation. Even though HDC is high-dimensional and algorithmically different from traditional cryptographic targets, the implementation still emits exploitable physical signatures.

In compliance language, the issue is an absence of adequate confidentiality-preserving controls around sensitive intermediate computations. The design allows physical observables to correlate with protected internal values strongly enough for a trained classifier to exploit them.

6.4 Control design

The core control is dynamic masking integrated into the computation pipeline. This is important because it is not merely a theoretical recommendation; it is an implementation-level protection

that changes the observability of sensitive values. The control is also resource-conscious, which matters in edge and embedded deployments.

In portfolio language, this control demonstrates the ability to choose a mitigation that balances security gain with hardware cost. That trade-off thinking is highly valued in real product teams.

6.5 Validation evidence

The project includes attack efficacy measurements before control application and post-control measurements after masking. It also includes TVLA-oriented leakage reasoning to show that the control reduces observable leakage rather than simply altering attack conditions.

This is exactly the type of evidence that audit and certification workflows need: a measurable baseline, a documented intervention, and a measurable result after the intervention.

6.6 Residual risk and improvement path

Residual risk remains because masking and unmasking points can still create opportunities for higher-order leakage or refined attack strategies. The portfolio therefore does not overclaim. Instead, it records the remaining concerns and proposes future hardening such as more comprehensive masked arithmetic or stronger implementation discipline.

That honest residual-risk statement increases credibility. Companies and evaluators trust engineers more when they know where the current boundary of assurance lies.

6.7 Compliance-style work products derived from the project

- Threat analysis and risk statement for model extraction via power side-channel leakage.
- Control description for dynamic masking and runtime protection of sensitive hypervectors.
- Validation memo summarizing attack results before and after control implementation.
- Evidence register containing trace captures, training configuration, evaluation logs, and leakage-assessment outputs.
- Residual-risk note and recommended next engineering actions.

6.8 Example portfolio wording for interviews and resumes

- Conducted threat analysis and vulnerability evaluation of FPGA-based AI accelerator against passive side-channel model extraction.
- Designed and evaluated a runtime masking control to reduce leakage from sensitive HDC operations.
- Produced audit-friendly evidence using measured traces, machine-learning attack evaluation, and leakage assessment.

7. Project dossier B - fault injection and robustness

This dossier converts the user's fault injection and glitching-related work into compliance language. In many product organizations, side-channel leakage and fault injection are treated as sister threat classes because both involve physical interaction with hardware and both can undermine security claims if not systematically evaluated.

The practical strength of this body of work is that it moves beyond abstract fault models. It includes hands-on use of equipment, timing-window reasoning, campaign design, and effect observation on the target system.

7.1 Protected assets and security objective

The primary protected asset is inference correctness. A physical attacker who can induce carefully timed faults may force misclassification, bypass intended behavior, or reveal implementation weaknesses.

A secondary protected asset is trust in system robustness. Safety- and security-sensitive applications require confidence that outputs remain reliable under perturbation or that attacks are at least detected.

7.2 Threat scenario

The attacker uses voltage glitching or timing disturbance, supported by equipment such as ChipWhisperer, to influence operations at precisely selected time windows. The attacker goal may be misclassification, differential behavior, security-boundary bypass, or identification of timing-sensitive critical operations.

In compliance language, this is a physical integrity attack against runtime execution.

7.3 Vulnerability analysis

The vulnerability often arises from timing-sensitive datapaths, insufficient detection of abnormal operating conditions, or a lack of redundancy/monitoring in critical operations. From a certification perspective, the key point is whether the system can tolerate, detect, or bound the effect of a disturbance.

This project stream is valuable because it builds intuition for where a hardware design becomes fragile under active manipulation.

7.4 Control strategies and engineering responses

Potential or explored controls include timing hardening, redundancy, fault detection sensors, protected reset/exception paths, conservative clocking margins, and architecture-level strategies that reduce single-point fault leverage.

Even where a control is not yet fully productized, the portfolio can still show that the engineer understands how to convert attack insights into product requirements.

7.5 Evidence and assurance value

Fault campaign logs, trigger configurations, successful/unsuccessful glitch windows, observed output deviations, and countermeasure comparisons all become evidence artifacts. Those artifacts are extremely useful in design reviews because they show that robustness claims were challenged experimentally rather than assumed.

Employees who can produce this evidence are useful not only for security roles but also for reliability, product assurance, and pre-silicon/post-silicon validation teams.

7.6 Compliance-language summary

- Performed active physical attack assessment focused on disturbance-based integrity compromise.
- Characterized timing-sensitive windows and documented attack feasibility under realistic lab conditions.
- Mapped observed weaknesses to candidate design controls and validation requirements.

8. Project dossier C - secure HDC accelerator design and verification

This dossier covers the user's broader accelerator-design work, including secure implementation of HDC components, architecture decisions, verification planning, and threat-aware design evolution. For compliance portfolios, this is important because companies do not only hire people who can break systems; they need engineers who can embed security requirements during design and verify them systematically.

The portfolio framing here is that the engineer understands how to move from attack observation to secure architecture, then to verification, and finally to evidence suitable for internal review.

8.1 System context

The system is an HDC accelerator with encoding, storage, and similarity computation components. Security relevance arises because the architecture processes sensitive representations and may be deployed in embedded or edge settings where physical exposure is plausible.

Architectural choices such as where data is stored, how operations are partitioned, and what timing structure exists can directly affect leakage and fault sensitivity.

8.2 Design responsibilities that map to compliance work

Threat-aware architecture selection, secure module decomposition, sensitivity-aware memory organization, measurement hooks for validation, and explicit verification planning all map well to formal security engineering responsibilities.

In hiring terms, this means the portfolio demonstrates not just reactive security evaluation but proactive secure-design thinking.

8.3 Verification and assurance view

Verification assets can include RTL simulations, directed tests, measurement triggers, profiling infrastructure, equivalence checks, and structured evaluation criteria for what counts as acceptable leakage or unacceptable behavior.

A compliance-minded engineer is expected to define what evidence must exist before a security claim is accepted. This project stream supports exactly that expectation.

8.4 Example control statements

Sensitive computation should be minimized, randomized, masked, partitioned, or otherwise structured such that a physical attacker cannot reliably infer protected data.

Critical runtime behavior should be instrumented or monitored in ways that support both debugging and assurance without creating new leakage channels.

8.5 Portfolio value for employers

- Can speak with both design engineers and evaluators using a common evidence vocabulary.
- Can help write security requirements that are specific enough to verify.

- Can bridge architecture, RTL, measurement, and security-review conversations.

9. Project dossier D - device-level and emerging hardware security

This dossier positions the user's device- and circuit-oriented work, including emerging technologies such as rFET-related security concepts, as part of a broader compliance and certification narrative. This is strategically valuable because many security portfolios stop at software or architecture level, whereas future hardware products increasingly need security reasoning that begins at the device and circuit layers.

The compliance translation is not that device-level research automatically equals certified security. Rather, it demonstrates the ability to reason from physical behavior upward: which device properties could support entropy, masking, obfuscation, or resistance to probing and leakage, and what evidence would be needed to justify those claims.

9.1 Relevance to certification and assurance

Certification teams often struggle when low-level security assumptions are vague. A candidate who can explain device behavior, model limitations, implementation trade-offs, and where circuit assumptions feed into system claims brings unusual value.

This work also supports future-facing product security because emerging devices require early-stage security thinking before standardized practice is mature.

9.2 Typical work products this stream can generate

Device-level threat notes, circuit-level security design rationales, characterization plans, modeling assumptions, and evidence roadmaps for what would be required before making a stronger product-security claim.

These artifacts matter in real companies because they help teams avoid overclaiming security based on incomplete low-level understanding.

9.3 How to present this work professionally

Frame it as security-enabling R&D: translating physical device behavior into candidate controls and into future assurance cases. Do not frame it as formal certified proof unless actual certification artifacts exist.

That balanced framing preserves credibility while still highlighting advanced expertise.

10. Cross-project traceability matrix

This matrix shows how multiple research streams can be organized into the kind of end-to-end logic that auditors and hiring managers expect.

Project	Asset	Threat	Key vulnerability	Representative control	Evidence
HDC SCA	Model IP in class hypervectors	Passive power-based extraction	Observable leakage during similarity operations	Dynamic masking	Measured attack reduction + leakage tests
Fault injection	Output integrity	Voltage/ timing glitching	Timing-sensitive execution windows	Detection/ hardening strategy	Campaign logs and output deviation analysis
Secure accelerator design	Runtime data flow	Leakage and exploitation opportunities	Security-unaware module structure	Threat-aware architecture + verification	RTL, simulation, profiling hooks
Device-level security	Low-level physical behavior	Predictable or exploitable device behavior	Insufficient characterization of low-level assumptions	Circuit/device masking and secure primitives	Modeling notes and characterization plans

Why this matters

Traceability is one of the biggest differences between a research profile and a compliance-ready profile. In a research profile, achievements are often organized by paper title or technical novelty. In a compliance-ready profile, the same work is organized by asset, risk, control, and evidence.

This section therefore functions as a portfolio backbone. It can be expanded for real product use into a living spreadsheet or requirement-management artifact.

11. Certification-style work products

This section shows the kinds of documents that the portfolio owner can credibly prepare or contribute to, based on the underlying PhD experience. The aim is not to falsely claim formal assessor status; the aim is to show readiness to work effectively with certification and compliance teams.

11.1 TARA-style note

Defines item scope, assets, attack paths, attacker capability assumptions, impact narrative, and candidate mitigations.

11.2 Security concept summary

Describes controls, architectural assumptions, interfaces, and how risk is reduced by design decisions.

11.3 Evaluation evidence memo

Summarizes experiments, metrics, observed weaknesses, applied controls, and remaining concerns.

11.4 Residual risk register

Documents what remains open, why it remains open, and what further activity is required before stronger claims can be made.

11.5 Security target support note

For Common Criteria style efforts, explains the target of evaluation, assets, threats, objectives, and rationale for implemented mechanisms.

11.6 Reviewer packet

Collects the exact files, scripts, figures, logs, and test summaries that a reviewer needs to inspect a claim.

Portfolio implication

This ability to generate the right package around technical work is often what separates an excellent researcher from a promotable product-security engineer.

12. Audit and evidence package

Audits are usually less interested in elegant theory than in disciplined evidence. An employee who understands this can dramatically improve the credibility of a security program. This section lists evidence categories that map naturally from the user's PhD work.

Evidence category	Why an auditor or reviewer cares
Trace captures and measurement context	Shows acquisition conditions, trigger alignment, device setup, and repeatability assumptions.
Attack scripts and model configuration	Shows exactly how the attack was executed and under what learning assumptions.
Pre-control and post-control comparison	Supports a control-effectiveness claim rather than a narrative-only claim.
Leakage assessment outputs	Provides an objective view of whether measurable leakage remains.
RTL/simulation artifacts	Useful when a claim depends on implementation details, timing windows, or control-signal behavior.
Design rationale notes	Explains why a specific control was selected rather than another.
Residual-risk note	Shows engineering honesty and helps future reviewers continue the work.

Audit readiness checklist

- Is the protected asset explicitly named?
- Is the attacker capability bounded and believable?
- Is the vulnerability stated in implementation terms rather than vague language?
- Is there evidence before and after the control?
- Is residual risk stated honestly?
- Can another reviewer reproduce or at least inspect the basis of the claim?

13. Role mapping for industry jobs

This section maps the portfolio to the language of real job families. The benefit is practical: the same project can be described differently depending on whether the role is certification-heavy, product-security-heavy, hardware-validation-heavy, or architecture-heavy.

Role family	What the employer wants	How this portfolio matches
Security Compliance Engineer	Structured risk, controls, evidence, audit communication	Provides traceability, control wording, evidence framing, and residual-risk logic
Certification / Evaluation Engineer	Security targets, assurance rationale, reviewer-facing packages	Provides Common-Criteria-style thinking and disciplined evidence language
Product Security Architect	Threat-aware design and cross-team decision support	Shows ability to translate attacks into architecture-level controls
Hardware Security Engineer	Practical attacks, countermeasures, measurement-backed results	Shows side-channel and fault-injection depth
ML / AI Platform Security Engineer	Protection of model IP and runtime behavior	Shows AI-specific threat and control framing

Targeted positioning sentence

I bring deep hands-on hardware security expertise and can translate that work into the evidence, traceability, and structured claims expected in compliance and certification workflows.

14. Interview stories and CV bullets

This section converts the portfolio into compact statements that can be used immediately in applications and interviews.

14.1 Short professional summary

Hardware and AI security researcher with practical experience in side-channel analysis, fault injection, secure accelerator design, and evidence-based security validation. Skilled at translating technical results into compliance-aligned work products such as threat analyses, control descriptions, verification evidence, and residual-risk statements.

14.2 Resume bullets

- Performed threat analysis and vulnerability evaluation of FPGA-based AI accelerators against passive side-channel attacks.
- Designed and evaluated runtime masking controls and measured their effect using attack metrics and leakage assessment.
- Executed active physical attack campaigns to characterize timing-sensitive fault injection behavior and robustness gaps.
- Developed security-aware accelerator design and verification workflows spanning RTL, profiling, and experimental measurement.
- Translated advanced research outputs into compliance-oriented evidence packages aligned to certification and audit expectations.

14.3 Interview answer template for 'Do you have compliance experience?'

My background is deeply technical, but I have structured my work in the same way compliance and certification teams operate. For each project I define the asset, the realistic attacker, the vulnerability, the control, the evidence, and the residual risk. I have done this for side-channel attacks, fault injection, secure accelerator design, and device-level security work. So while I may not claim to have been the formal certifier, I do have strong hands-on experience producing the technical backbone that those workflows depend on.

15. Personal gap-closure plan

A good portfolio is honest about both strength and growth areas. This section turns the remaining gap from 'I do not know compliance' into a concrete development plan.

Action	Why it matters	Suggested timeline
Learn the vocabulary deeply	Study official framework structure and common work-product names so interviews feel natural.	4-6 weeks
Practice on past projects	Convert two or three additional papers into the same portfolio template.	2-4 weeks
Add one recognized training	Pursue one relevant training or certificate for HR signaling.	Variable
Create reusable evidence templates	Maintain personal templates for TARA notes, evidence registers, and residual-risk logs.	1-2 weeks
Apply in role language	Tailor CV and LinkedIn around compliance, certification, and assurance wording.	Immediate

Key mindset shift

The missing piece is not security intelligence. The missing piece is packaging. Deep technical work becomes compliance-ready when it is translated into structured claims, controls, evidence, and traceability.

16. Final positioning statement

This portfolio demonstrates that the user's PhD work is not isolated academic output. It is a rich base for security compliance, certification support, evaluation engineering, and product-security roles.

The strongest message for employers is this: the candidate already knows how to think like an attacker, build like an engineer, and validate like a reviewer. The portfolio now makes that visible in the language that companies understand.

A technically deep candidate who can also package evidence and traceability is rare. That rarity should be treated as a strategic advantage.

Appendix A - standards language quick reference

The entries below are intentionally simplified so that the portfolio remains readable. They are phrased as working language rather than quoting standards text.

Term	Working meaning
Asset	What must be protected because it carries security or business value.
Threat	A plausible adverse action by an attacker.
Vulnerability	A weakness or design property that increases attack feasibility.
Control	A design or process element intended to reduce risk.
Evidence	Artifacts that support the claim that a control exists and works.
Residual risk	What remains after the control is applied.
Assurance	The degree of justified confidence in the claim.
Traceability	The chain that links requirement, risk, control, and evidence.

Appendix B - evidence inventory template

The following structure can be reused for any future project.

- Project identifier and version
- Protected asset
- Threat statement
- Control version / configuration
- Evidence items collected
- Date, owner, and storage location
- Validation result summary
- Residual-risk note
- Open actions

Source note

The HDC side-channel dossier in this portfolio is informed by the user's uploaded ICCAD paper on deep-learning-assisted side-channel attacks on HDC accelerators. Other sections are derived from the user's broader research themes and project descriptions discussed across the conversation.